ТУСУР
TUSUR UNIVERSITY

Соответствие

Управление информационной безопасностью. Лекция 2.14

18 Соответствие

Раздел включает в себя 2 категории и 8 мер обеспечения информационной безопасности:

18.1 Соответствие правовым и договорным требованиям
Цель: Избежать нарушений правовых и регулятивных требований или договорных обязательств, связанных с ИБ, и других требований безопасности.

- 18.1.1 Идентификация применимых законодательных и договорных требований
- 18.1.2 Права на интеллектуальную собственность
- 18.1.3 Защита записей
- 18.1.4 Конфиденциальность и защита персональных данных
- 18.1.5 Регулирование криптографических мер обеспечения информационной безопасности

18.2 Проверки информационной безопасности
Цель: Обеспечить уверенность в том, что ИБ реализована и эксплуатируется в соответствии с политикой и процедурами организации.

- 18.2.1 Независимая проверка информационной безопасности
- 18.2.2 Соответствие политикам и стандартам безопасности
- 18.2.3 Анализ технического соответствия

Идентификация применимых законодательных и договорных требований

ТУСУР
TUSUR UNIVERSITY

Все соответствующие законодательные, нормативные, контрактные требования, а также подход организации к удовлетворению этих требований должны быть явным образом определены, документированы и сохраняться актуальными для каждой информационной системы и организации.

Конкретные меры и индивидуальные обязанности по выполнению этих требований также должны быть определены и задокументированы.

Руководство должно определить все законодательные акты, требования которых применимы к бизнесу организации и должны выполняться. Если организация ведет бизнес в нескольких странах, руководство должно учитывать требования каждой страны.

Права на интеллектуальную собственность

Должны быть реализованы соответствующие процедуры для обеспечения уверенности в соблюдении правовых, регулятивных и договорных требований, связанных с правами на интеллектуальную собственность и правами на использование проприетарных программных продуктов.

В отношении любых материалов, которые могут рассматриваться как интеллектуальная собственность, необходимо рассмотреть следующие рекомендации:

a) выпуск политики соблюдения прав на интеллектуальную собственность, которая определяет законное использование программного обеспечения и информационных продуктов;
b) приобретение программного обеспечения только у известных и доверенных источников для гарантии того, что авторское право не нарушается;
c) поддержание осведомленности о политике защиты прав интеллектуальной собственности и уведомление о намерении принять дисциплинарные меры в отношении нарушителей;
d) ведение соответствующих реестров активов и идентификация всех активов с требованиями по защите прав интеллектуальной собственности;
e) сохранение подтверждений и свидетельств прав собственности на лицензии, диски с дистрибутивами, руководства и т.д.;
f) внедрение мер обеспечения ИБ для гарантии того, чтобы не было превышено максимальное количество пользователей, установленное в рамках лицензии;

Права на интеллектуальную собственность

g) проведение проверок на предмет того, что установлено только авторизованное программное обеспечение и лицензионные продукты;
h) предоставление политики по поддержке соответствующих лицензионных соглашений;
i) предоставление политики по утилизации или передаче программного обеспечения другим лицам;
j) соблюдение условий использования программного обеспечения и информации, полученных из общедоступных сетей;
k) не дублировать, конвертировать и извлекать информацию из коммерческих записей (видео, аудио), если это нарушает законы об авторском праве;
l) не копировать полностью или частично книги, статьи, отчеты и другие документы, кроме разрешенных законом об авторском праве.

Права на интеллектуальную собственность

Права на интеллектуальную собственность включают в себя авторское право на программное обеспечение или документы, права на проекты, торговые марки, патенты и лицензии на исходный код.

Проприетарные программные продукты обычно поставляются в соответствии с лицензионным соглашением, в котором указывают условия лицензии, например ограничение использования продукта конкретным компьютером или ограничение копирования только созданием резервных копий. Ситуацию в отношении прав на интеллектуальную собственность на программное обеспечение, разработанное организацией, следует разъяснить персоналу.

Законодательные, нормативные и договорные требования могут вводить ограничения на копирование материалов, являющихся предметом собственности. В частности, данные ограничения могут содержать требования на использование только тех материалов, которые разработаны организацией или предоставлены по лицензии, или переданы разработчикам для организации. Нарушение авторского права может привести к судебному иску, который может повлечь за собой штрафы и уголовное преследование.

Защита записей

Записи должны быть защищены от потери, уничтожения, фальсификации, несанкционированного доступа и разглашения в соответствии с правовыми, регулятивными, договорными и бизнес-требованиями.

При принятии решения о защите определенных документов организации следует учитывать то, как они классифицированы по схеме организации. Записи должны быть разделены на типы, например бухгалтерские счета, записи баз данных, журналы транзакций, журналы событий и эксплуатационные процедуры. Для каждого из типов должен быть определен период хранения и допустимый носитель, например бумага, микрофиша, магнитная лента, оптические диски. Все криптографические ключи и программы, имеющие отношение к зашифрованным архивам или цифровым подписям, также должны сохраняться, чтобы обеспечить возможность расшифровывания записей во время их хранения.

Защита записей

Следует учитывать возможность порчи носителей, используемых для хранения записей. Процедуры их хранения и обработки должны осуществляться в соответствии с рекомендациями производителя.

Там, где выбираются электронные носители данных, должны быть установлены процедуры, обеспечивающие возможность доступа к данным (читаемость носителей и формата данных) в течение срока их хранения с целью защиты от потери в результате будущих изменений технологии.

Системы хранения данных следует выбирать таким образом, чтобы требуемые данные могли быть извлечены в приемлемые сроки и в приемлемом формате в зависимости от применимых требований.

Система хранения и обработки должна обеспечивать четкую идентификацию записей, а также период их хранения, установленный соответствующими национальными или региональными законами и нормами. Необходимо, чтобы эта система предоставляла возможность уничтожения документов после того, как у организации отпадет потребность в их хранении.

Для достижения целей защиты записей в организации должны быть предприняты следующие шаги:

a) должны быть выпущены руководящие принципы по срокам, хранению, обработке и утилизации записей и информации;
b) должен быть составлен график хранения с указанием записей и периода времени, в течение которого они должны храниться;
c) следует вести перечень источников ключевой информации.

Конфиденциальность и защита персональных данных

ТУСУР
TUSUR UNIVERSITY

Конфиденциальность и защита персональных данных должна обеспечиваться в соответствии с требованиями соответствующих законодательных и нормативных актов там, где это применимо.

Должна быть разработана и внедрена политика организации в отношении конфиденциальности и защиты персональных данных. Эта политика должна быть доведена до сведения всех лиц, участвующих в обработке персональных данных.

Соблюдение этой политики и всех соответствующих законодательных актов и требований регуляторов, касающихся защиты неприкосновенности частной жизни людей и защиты персональных данных, требует подходящей структуры управления и контроля. Зачастую это лучше всего достигается назначением ответственного лица, такого как работника, ответственного за конфиденциальность, который должен предоставлять указания менеджерам, пользователям и поставщикам услуг относительно их индивидуальных обязанностей и конкретных процедур, которые они должны соблюдать. Ответственность за обработку персональных данных и обеспечение осведомленности о принципах конфиденциальности должна рассматриваться в соответствии с применимым законодательством и требованиями регуляторов. Должны быть приняты подходящие технические и организационные меры для защиты персональных данных.

Регулирование криптографических мер обеспечения информационной безопасности

ТУСУР
TUSUR UNIVERSITY

Криптографические меры обеспечения информационной безопасности должны использоваться с соблюдением требований всех соответствующих соглашений, правовых и регулятивных актов.

Для соответствия применимым соглашениям, правовым актам и требованиям регуляторов, следует рассмотреть:

a) ограничения на импорт или экспорт компьютерного оборудования и программного обеспечения, выполняющего криптографические функции;
b) ограничения на импорт или экспорт компьютерного оборудования и программного обеспечения, спроектированного с учетом того, что в них могут быть добавлены криптографические функции;
c) ограничения на использование шифрования;
d) обязательные или добровольные методы доступа государственных органов к информации, зашифрованной с использованием аппаратного или программного обеспечения для обеспечения конфиденциальности информации.

Следует обратиться за юридической консультацией по вопросам соблюдения применимых законодательных и нормативных актов. Прежде, чем зашифрованная информация или криптографическое средство покинет границы юрисдикции, следует также получить юридическую консультацию.

Независимая проверка информационной безопасности

ТУСУР
TUSUR UNIVERSITY

Подход организации к менеджменту ИБ и ее реализация (т.е. цели, меры и средства, политики, процессы и процедуры ИБ) должны проверяться независимо друг от друга через запланированные интервалы времени или в случае значительных изменений.

Руководство должно инициировать проведение независимой проверки. Такая независимая проверка необходима для обеспечения постоянной пригодности, адекватности и эффективности подхода организации к управлению ИБ. Проверка должна включать оценку возможностей для улучшения и необходимости изменений в подходе к безопасности, включая задачи политики и мер обеспечения ИБ.

Такая проверка должна выполняться лицами, не связанными с проверяемой областью, например теми, кто проводит внутренние аудиты, независимыми руководителями или сторонними организациями, специализирующимися на проведении таких проверок. Лица, проводящие проверки, должны иметь соответствующие навыки и опыт.

Результаты независимой проверки должны быть задокументированы и доведены до сведения руководства, которое инициировало проверку. Эти записи должны сохраняться.

Если независимая проверка выявляет, что подход организации и реализация управления ИБ недостаточны, например документированные цели и требования не выполняются или не соответствуют направлению ИБ, установленному в политиках ИБ, руководство должно рассмотреть необходимость корректирующих действий.

Соответствие политикам и стандартам безопасности

Руководители, в пределах своей зоны ответственности, должны регулярно проверять соответствие процессов и процедур обработки информации соответствующим политикам ИБ, стандартам и любым другим требованиям безопасности.

Руководство должно определять, каким образом проверять соответствие требованиям ИБ, определенным в политиках, стандартах и других применимых нормативных актах. Необходимо рассмотреть возможность применения инструментов автоматизированного анализа и формирования отчетности для обеспечения эффективных регулярных проверок.

Если в результате проверки обнаружено несоответствие, руководству следует:

a) выявить причины несоответствия;
b) оценить необходимость выполнения действий для обеспечения соответствия;
c) принять соответствующие корректирующие меры;
d) проверить эффективность предпринятых корректирующих действий и выявить любые недостатки или слабости.

Результаты проверок и корректирующих действий, выполненных руководством, должны быть зафиксированы, а эти записи должны быть сохранены. Руководство должно сообщить о результатах лицам, проводящим независимые проверки, когда проводится независимая проверка в области их ответственности.

Анализ технического соответствия

Информационные системы должны регулярно проверяться на предмет соответствия стандартам и политикам ИБ организации.

Техническое соответствие должно проверяться предпочтительно с помощью автоматизированных инструментов, которые генерируют технические отчеты для последующей интерпретации техническим специалистом. Кроме этого, опытный системный инженер может проводить ручные проверки (с использованием соответствующих программных средств, при необходимости).

Если используются тесты на проникновение или оценка уязвимостей, следует проявлять осторожность, поскольку такие действия могут привести к нарушению безопасности системы. Такие тесты следует планировать, документировать и повторять.

Любая проверка технического соответствия должна проводиться только компетентными уполномоченными лицами или под их наблюдением.

Рассмотренные вопросы

Соответствие:

- Идентификация применимых законодательных и договорных требований. Существующие законодательные требования
- Защита записей
- Проверки информационной безопасности (независимая проверка ИБ, соответствие политикам и стандартам, анализ технического соответствия)

Почитать

- ГОСТ Р ИСО/МЭК 27002-2021

ТУСУР
TUSUR UNIVERSITY

Всем спасибо – все свободны,

если нет вопросов!